AI Grid: from customer demos to enterprise AI security

One-year execution plan and three-year strategy | Prepared 28 September 2026

Planning horizon: October 2026-September 2027; extending to September 2029. Months are relative to an October start and can shift together. **Team:** 2-4 people, as confirmed. **Stage:** customer demos; pursuing the first customer. **Audience:** founders, product/engineering, and prospective design partners.

1. The strategic choice

Make AI Grid the security evidence and control layer that helps enterprises approve, operate, and improve their use of AI. Start by proving that value for one AI environment and one customer workflow.

The strongest near-term promise is: **Know which AI systems are deployed in the connected environment, who owns them, which supported security controls fail, and what evidence proves the gaps were fixed.** Report actual usage only where supported activity evidence exists. Over three years, extend this into attributable agent activity and controlled actions through the customer's existing gateways and tools.

The bank strategy's most commercially useful signal is on PDF page 49: approval cycles can exceed development timelines, while risk teams ask repeated or inconsistent questions. AI Grid should reduce the security work needed to reach an approval decision, while keeping the bank's risk owners in control. The strategy also calls for inventory, identity, privacy-preserving telemetry, policy checks, and audit evidence. [B, pp. 11-17, 21, 29-36, 49]

AI Grid already implements much of the posture-and-evidence foundation. The first-year investment should concentrate on customer validation, secure deployment, dependable evidence, and repeatable operation. A feature shown in the application or implemented in source is not yet a customer-proven enterprise capability.

Horizon	Customer outcome	Business gate
Year 1: trusted visibility and evidence	One team can discover its supported AI estate, resolve material control gaps, and submit a reusable security evidence pack.	First paid production customer; a second independent paid pilot or deployment validates the same core offer.
Year 2: attributable activity and bounded control	Operators can reconstruct supported agent actions; at four-person capacity, one integrated tool boundary can enforce approved rules.	First renewal or expansion; repeat demand for the runtime capability before making it a supported product.
Year 3: continuous assurance across selected systems	Changes in assets, identities, components, or policies trigger reassessment and usable evidence across a small number of supported environments.	Repeat renewals and expansion, bounded delivery effort, and support economics that justify every added surface.

All targets and DoDs in this document are proposed acceptance criteria, not achieved results or revenue forecasts. Confirm baselines, contractual targets, and customer responsibilities at pilot kickoff. Geography, budget, current production configuration, and willingness to pay remain unconfirmed.

Reading guide: Sections 2-4 explain the evidence and positioning. Sections 5-8 contain the one-year roadmap. Sections 9-10 define enterprise release and pilot acceptance. Sections 11-14 contain the three-year roadmap. Sections 15-17 cover capacity, decisions, and sources. DoD means **Definition of Done**.

2. What the bank strategy means for AI Grid

The attached document is source material, not an instruction to implement every bank initiative. Its 2025-2030 vision and February-April 2026 plans describe intent; they do not establish what the bank has deployed today. Page references below use the **49-page PDF's page numbers**, not embedded slide numbers.

Bank requirement and evidence	AI Grid response	Timing
Approval delays and duplicated risk questions; reusable reviews and patterns [B, p. 49]	One evidence pack, clear missing-evidence tasks, named reviewers, and reusable control checks. Measure preparation effort and rework.	Year 1 core
Enterprise AI map, governance synchronization, and grey AI [B, pp. 11-13]	Reconcile discovered cloud assets with declared inventory. Show supported scope, unregistered assets, and blind spots separately.	Year 1 cloud scope; broader feeds later
Approved purpose, sensitivity, residency, and legal-entity constraints [B, pp. 15-16]	Add only the context needed for the pilot's controls; import authoritative business context where available.	Year 1
Risk owners retain policy intent and thresholds [B, pp. 7-9, 16]	Versioned customer-approved controls, explanations, exceptions, and exportable evidence. Final risk acceptance remains with the customer.	Year 1 onward
Explicit user/agent/tool identities and least privilege at tool boundaries [B, pp. 29-32]	First assess identity configuration; later correlate runtime actors and integrate policy checks with existing enforcement.	Years 1-2
Shared telemetry with sensitive records treated before distribution [B, pp. 34-36]	Metadata-first collection, provenance, redaction checks, explicit retention, and approved evidence destinations.	Year 1 foundation; runtime in Year 2
Ticketed material-action approval, evidence packs, later in-flow controls [B, p. 21]	Sequence observation, verified remediation, runtime evidence, then a bounded enforcement integration.	Years 1-3
Sovereignty and protected workloads [B, pp. 8, 39-40]	Agree one viable region/deployment with the first customer. Add customer-controlled deployment only with funded demand.	Year 1 decision; conditional Year 3 expansion
Model discovery, security, lineage, and governance tools [B, pp. 46, 48]	Reuse provenance and approved-version records; integrate specialist scanner/model-risk results before considering native scanning.	Years 2-3

The architecture diagrams already separate identity, policy, gateways, observability, and security services. AI Grid should integrate into that architecture. The bank also insists on retaining its institutional policy and business knowledge. An interoperable security component is therefore a more credible offer than a replacement AI platform. [B, pp. 7-9, 18-20, 46]

Scope discipline: Enterprise chat, an AI marketplace, model hosting/training, orchestration, quantum research, workforce productivity analytics, and full banking model-risk management are outside this strategy. AI Grid can exchange evidence with those systems.

3. The actual starting point

This assessment used a read-only review of the current working tree, including existing local changes. It did not run the application, connector credentials, production queries, or test suites. The following describes implementation evidence, not certified production operation.

Area	Evidence in the repository	Roadmap implication
Discovery and inventory	AWS, Azure, and Copilot metadata collectors; API-backed inventory and relationship views. [C1-C3]	Harden the first buyer's provider and publish its exact coverage. Do not rebuild inventory or promise all-cloud parity.
Evidence and assessment	Hashed snapshots, ownership resolution, governed policies, explicit missing/stale evidence states, and bounded exposure correlations. [C2, C4]	Validate the quality and provenance of a small control pack on customer examples.
Remediation	Canonical findings, accountable owners, triage, reassessment, and ServiceNow incident creation. [C5-C6]	Prove the complete fix-and-verify workflow; existing integration code needs customer qualification.
Identity and isolation	JWT support, role checks, schema-per-tenant routing, production safety checks, and RLS protections. [C7-C8]	Complete and test the first customer's SSO, role lifecycle, and production configuration.
Content governance	Policy versions, precision review, release approval, canary distribution, and effective-coverage semantics. [C2, C9]	Operationalize these gates; mapped framework controls are not automatically effective controls.
Runtime foundations	Metadata ingestion, execution/event records, preview runtime policies, producer certification, and readiness logic. [C2, C10-C11]	Runtime is a later validation track. The reviewed collectors cannot establish authoritative decisions for important actions.
Engineering and operations	Root CI, migration checks, test jobs, retention/hold handling, and budget controls exist. [C2, C12]	Verify actual passing release results, recovery, scale, and support. Some README statements about absent CI are stale.

Three distinctions must remain visible in sales and the product:

- **Configured or reachable is not observed misuse.** A path to sensitive data is an exposure hypothesis unless the required evidence validates it. A configured guardrail is not proof that it stops attacks.
- **Hashing is not independent tamper-proof storage.** The existing hashes and manifests are useful foundations; stronger immutability requires an appropriate storage and verification design.
- **A preview policy is not a production control.** Runtime packs remain preview/paused in the reviewed material. Demo-only policy auto-publication defaults off; verify it stays off for customer operation and exclude synthetic approvals from acceptance. [C2, C9-C11]

The strongest asset is the connected workflow: **resource -> evidence -> control decision -> owner -> remediation -> fresh verification**. The highest-priority gap is proving that workflow under a customer's access, data, and operating constraints.

4. Product and commercial strategy

Vision: Enterprises can adopt useful AI while knowing its security boundaries and being able to demonstrate that those boundaries hold.

First segment: A banking business unit, regulated financial-services team, or comparable regulated enterprise with deployed cloud AI, an imminent security review, a named AI platform owner, and authority to buy a bounded pilot. Banking is the reference segment, not evidence that the attached bank will purchase. A smaller institution or independently funded unit may be a better first customer than a bank-wide procurement.

Buying group: AI security lead or CISO delegate owns the security outcome; platform engineering supplies integration access; risk/compliance accepts the evidence; procurement and a named budget owner govern the purchase. Users are security analysts, application owners, and platform engineers.

Customer job	Current alternative to validate in interviews	AI Grid's proposed value
Establish what AI is deployed and who is responsible	Spreadsheets, cloud consoles, manual attestations	Reconciled, evidence-backed inventory for the connected scope
Determine what prevents security approval	Repeated questionnaires and separate control reviews	Reusable control evidence with clear gaps and next actions
Resolve and prove a security improvement	Tickets disconnected from assessment state	Traceable remediation with fresh re-evaluation

First offer: A fixed-scope, paid six-week AI security baseline and evidence pilot, beginning after agreed access is available. One business unit, one provider, 1-3 accounts/subscriptions, 2-5 representative AI applications if available, and 5-8 qualified controls. For smaller estates, use the complete agreed population. Contract discovery coverage by supported resource type, not by an unverified estimate of all organisational AI.

The deliverable is a reviewer-accepted security evidence pack and verified remediation workflow. Demonstrate three agreed control scenarios with sanctioned test cases when the live estate does not contain real failures. Do not manufacture customer incidents to meet a quota.

Packaging hypothesis: A pilot fee can be credited toward a first annual agreement. Annual pricing should combine a base platform fee and bounded monitored scope, with a transparent allowance for telemetry if sold later. Confirm willingness to pay with current demo prospects before setting price points. Avoid alert-based pricing or unlimited custom integration commitments.

Go-to-market: Founder-led discovery and sales; one repeatable demo; one technical/security evidence pack; one documented onboarding route. Use references only with permission. Treat system integrators and security partners as delivery or referral options after they identify a concrete shared opportunity. Existing local GTM material supports a focused pilot motion; this plan uses the user's smaller team and bank reference to narrow it further. [C13]

Build and defend: Own the AI relationship/evidence model, explainable control outcomes, policy validation, and fix verification. Reuse managed identity, storage, observability, ticketing, and customer policy engines. Defensibility must be earned through trusted integrations, validated controls, and low reviewer effort; a larger policy count is not a durable advantage. Do not pool customer telemetry without a separate lawful, agreed basis.

5. Year 1, phase 1: earn the first paid pilot

Months 1-3 | October-December 2026 | Outcome: One qualified buyer can trust a bounded AI security assessment. First two weeks establish scope; the rest proves it. **Dependency:** customer access and named reviewers. **Accountable:** founder/product lead and engineering lead; the customer signs acceptance.

Y1-01. Contract one problem and establish product truth

Work: Interview 6-8 current demo prospects or comparable buyers; select one repeated problem, provider, and workflow. Create a capability matrix separating implemented, customer-validated, preview, and unsupported features. Agree the deployment/data boundary and procurement path.

DoD: A pilot charter names sponsor, operator, risk reviewer, scope, access owner, baseline metrics, acceptance tests, commercial terms, and decision date. A signed paid pilot or purchase order is the commercial exit target. Sales claims and demo screens match the tested capability matrix. If no buyer will commit after these conversations, revise the offer before broadening engineering scope.

Y1-02. Establish the minimum secure customer environment

Work: Reuse production auth/isolation and deploy one supported configuration. Complete one customer IdP path, read-only collector permissions, secret handling, safe support access, and metadata handling.

DoD: Customer security owner accepts region, data flow, access scopes, retention, and subprocessors. Production-profile authentication, forbidden-role actions, tenant isolation, revocation, and privileged-support audit checks pass. Demo seed/auto-publication is verified off. A focused independent security assessment has no unresolved critical/high issues in the pilot boundary before production data is admitted. If access is only to a sanitized evaluation environment, label that boundary explicitly.

Y1-03. Make discovery dependable and coverage honest

Work: Qualify existing collection for the chosen provider; reconcile asset IDs and ownership; surface permission errors, unsupported resource types, stale data, and deleted resources.

DoD: Discover at least 95% of the independently enumerated, supported, in-scope resource population. Account for every discrepancy; report unsupported scope separately. Every critical in-scope AI system has a confirmed owner. Fourteen consecutive days meet the agreed daily collection schedule; failed scans alert and never turn old evidence into a pass. The first usable baseline is delivered within seven business days of access readiness.

Y1-04. Certify 5-8 controls and prove a real workflow

Work: Select controls that the customer's available evidence can actually support. Reuse policy review, findings, owner routing, and reassessment. Candidate controls appear in section 10.

DoD: Every released control has positive, benign, missing, stale, and permission-denied tests, a version, reviewer approval, and customer examples. Achieve at least 90% precision on the reviewed alert sample; report sample size and uncertainty. A holdout scenario set detects at least 90% of the agreed supported violations; this is scenario coverage, not universal attack recall. Production release also passes each control's existing digest-bound answer-key, precision, bias, and independent-review gates. Current defaults include a 95% Wilson lower-bound precision threshold at 95% confidence, with two independent reviewers for high/critical policies. The 90% pilot operating metric and initial sample floors do not authorize release. Demonstrate three agreed control scenarios, one accepted remediation, and a fresh scan proving its outcome. The customer reviewer accepts the first evidence pack.

Phase exit: A paid pilot is active or complete, the first supported environment meets Y1-02, and Y1-03/Y1-04 evidence is reviewable. Procurement delay does not justify claiming a customer win or adding unrelated features.

6. Year 1, phase 2: convert evidence into a production service

Months 4-6 | January-March 2027 | Outcome: The first customer uses AI Grid in its operating process and pays for continued value. **Dependency:** phase 1 evidence. **Accountable:** engineering lead for delivery; founder for conversion; customer security lead for acceptance.

Y1-05. Complete the remediation and exception lifecycle

Work: Qualify one workflow destination: existing ServiceNow if the customer uses it, otherwise a scoped export or one small adapter. Define severity mapping, owner assignment, due dates, false-positive handling, and expiring risk acceptance.

DoD: Ticket creation is idempotent; failures/retries are visible; a ticket is traceable to policy and evidence. The agreed workflow handles open, accepted risk, expired exception, verified resolved, and reopened states. One repeated scan does not create duplicate work. A disabled policy or closed ticket is never counted as verified remediation. At least two customer-owned cases complete the intended lifecycle, using sanctioned exercises if necessary.

Y1-06. Produce reusable security approval evidence

Work: Export a compact application/control report with approved purpose, owner, risk context, observations, decision version, exceptions, and supporting evidence. Retain existing customer GRC/CMDB identifiers. Start with export/import rather than full bidirectional synchronization.

DoD: A reviewer can trace every released pilot control to resource, source, timestamp, policy version, result, and disposition. Export totals reconcile to the UI. Missing/unsupported controls stay visible. Retention, deletion, and legal-hold behavior pass agreed tests. Two review exercises show at least 50% less active evidence-preparation effort than the recorded manual baseline, without omitted required evidence. If the target is missed, record the cause and remediate the workflow; do not report faster overall approvals unless measured.

Y1-07. Establish recoverability, support, and paid production

Work: Put the service on a customer-approved paid/managed deployment. Validate alarms, backups, restore, upgrade/rollback, and incident ownership. Provide a security architecture pack, operating runbook, known limitations, support hours, and escalation contacts.

DoD: A witnessed isolated restore meets proposed RPO of 24 hours and RTO of 8 hours, or stricter signed customer targets. Thirty days of service monitoring meet a proposed 99.5% monthly availability SLO; instrument downtime and disclose maintenance separately. No unresolved critical/high production-scope security findings remain. The customer accepts the operational pack and signs a paid production agreement or pilot expansion with a dated production decision.

Phase exit: Target one paying production customer by month 6. If product outcomes pass but procurement is pending, keep a dated mutual action plan. If the sponsor rejects the value or will not pay, pause adjacent expansion and reassess the buyer/problem. Bank-wide adoption is not required for this milestone.

Scope cap: One provider, one primary control pack, one customer workflow integration, one supported deployment model. More controls are justified only when they change the customer's decision or reduce operating effort.

7. Year 1, phase 3: make the same value repeatable

Months 7-9 | April-June 2027 | Outcome: A second buyer can receive the core outcome without a bespoke product. **Dependency:** first production customer and stable support load. **Accountable:** founder for selection; engineering lead for repeatability.

Y1-08. Add use-case context and continuous reassessment

Work: Tie a small set of application attributes to controls: owner, business purpose, sensitivity, environment, approved region/provider, and applicable policy set. Detect material changes and reopen the right review or finding. Reuse existing version/manifest capabilities where applicable.

DoD: A controlled change in ownership, approved region, material tool permission, or approved component triggers the expected reassessment in all agreed test cases. Each context field shows whether it is discovered, imported, or attested, with timestamp and owner. Revoked or expired approval is visible. A minimum of two application reviews reuse the same template; final approval is recorded by an authorized customer reviewer, not inferred from a green dashboard.

Y1-09. Qualify a second independent customer

Work: Sell the same use case, preferably on the same provider. Turn first-customer deployment steps and permission troubleshooting into a guided checklist. Keep customer differences in configuration rather than code forks.

DoD: A second customer signs a paid pilot or production agreement and obtains a usable baseline within seven business days of access readiness. Core installation takes at most five engineering days, excluding customer waiting time, with no separate application fork. Acceptance reuses the same controls and tests; customer-specific work consumes no more than 20% of the pilot delivery effort. If these limits are missed, improve repeatability before selling a third architecture.

Y1-10. Make quality and operating cost visible

Work: Add a customer scorecard for supported coverage, evidence freshness, precision, open critical gaps, verified fixes, preparation effort, and integration health. Measure hosting and hands-on support cost per customer.

DoD: All metrics have a defined denominator and source; unknown and not-assessed results appear separately from pass rates. A 30-day operating review shows no silent collector outage and no lost accepted evidence during tested retries/restarts. Routine support is at most four engineering hours per customer per week after onboarding; higher effort triggers a capacity or pricing change before further expansion.

Phase exit: Two independent customers have validated the same core offer, with at least one in paid production. The second customer may still be in pilot; do not count it as production revenue.

8. Year 1, phase 4: earn renewal and choose the next boundary

Months 10-12 | July-September 2027 | Outcome: A narrow, dependable enterprise product with evidence to choose Year 2. **Dependency:** repeat delivery and measured support economics. **Accountable:** founder and engineering lead jointly.

Y1-11. Validate the supported enterprise operating envelope

Work: Re-run the release process in production-equivalent settings, close support gaps, and test the customer's agreed asset counts, scan schedules, concurrency, storage growth, and export volumes.

DoD: Load tests pass at twice the largest contracted in-scope inventory, with results and limits published. Propose p95 under two seconds for common inventory/finding reads at that load; agree different targets before testing if necessary. Repeat restore and upgrade rollback successfully. Availability meets the signed SLO across the final 60 days. A current independent assessment and retest show no unresolved critical/high issues in the supported deployment. No new architecture is sold outside the tested envelope.

Y1-12. Validate retention and decide the next paid expansion

Work: Hold a customer value review and assess renewal/expansion intent. Compare demand for another provider, runtime evidence, stronger audit storage, or broader unregistered-AI discovery. Select one priority.

DoD: First customer remains active and paying; an economic buyer documents measured value and renewal or expansion intent. A second independent paid engagement validates the core workflow. A Year 2 investment brief names two interested customers, available evidence, delivery/support cost, commercial value, and acceptance criteria. Without that evidence, fund reliability and retention instead of broadening the platform.

Y1-S1. Four-person stretch: one expansion experiment

Work: Choose either one additional existing connector qualification **or** one customer-telemetry observation experiment. Reserve at most 15% of quarterly delivery capacity. This is not required for the first-year core.

DoD: Connector option passes the same coverage/privacy tests as the first provider and has a paying sponsor. Telemetry option delivers an attributable, metadata-only incident reconstruction in a sandbox and reports missing authoritative fields. It remains an explicitly scoped experiment; existing Program 2 readiness is not represented as achieved by one adapter. No inline blocking or production enforcement is included.

Year 1 success at two people: One renewed/continuing paid production customer, one second paid evaluation, 5-8 trusted controls, and repeatable evidence/remediation on one provider. **At four people:** Aim for two paid production customers and one qualified expansion experiment, while meeting the same quality gates. These are management targets, not predictions.

Explicitly deferred: broad employee/browser shadow-AI collection, all-cloud parity, proprietary prompt-injection detection, agent hosting, full red-team automation, autonomous remediation, native model-risk management, and simultaneous SaaS/private/air-gapped deployment support.

9. Definition of enterprise-ready for the supported scope

Every production roadmap item inherits the relevant checks below. These are release conditions; delivery dates do not override them. Accountable owners collect evidence, and the customer accepts product outcomes in the agreed boundary.

Dimension	Required evidence before calling the capability done
Identity and authorization	One supported enterprise SSO path, correct role mapping, IdP MFA policy where required, deny-path tests, access revocation, audited administration, and tenant-isolation checks in production configuration. A proposed revocation limit is 15 minutes or the customer's stricter requirement.
Data protection	Approved data-flow diagram; encrypted transport/storage; managed credentials; metadata allowlist and sensitive-data canary tests; configurable agreed retention; verified purge/hold behavior. No raw prompt or response capture by default.
Trustworthy results	Provenance, timestamps, resource scope, policy/version, reproducible tests, and named reviewer for every released control. Missing evidence is unknown or not assessed. Confidence and coverage limitations are explicit.
Safe change	Actual passing CI artifacts, migration validation, release notes, canary rollout, rollback test, versioned policy approval, and production demo flags off. Existing pipelines are reused and strengthened where evidence is missing.
Reliability	Instrumented availability, collector freshness, retry/duplicate handling, tenant quotas, backlog alerts, backup/restore proof, and agreed scale envelope. A failed scan does not erase or falsely resolve risk.
Support and procurement	Signed support coverage and escalation, incident runbook, customer security questionnaire, hosting/subprocessor information, vulnerability response process, and export/exit plan. No implicit 24/7 staffed support commitment.
Independent assurance	Focused external testing before sensitive production onboarding and after material boundary changes; critical/high issues fixed and retested. Obtain formal assurance reports only when customer demand and budget justify the exact scope.

Use versioned framework mappings as navigation for reviewers. NIST describes AI RMF as voluntary and publishes a generative-AI companion profile; neither a mapping nor AI Grid itself certifies a customer as compliant. The current NIST page also notes revision activity, so pin the version used in each evidence pack. [N1-N2]

OWASP's published 2026 LLM guide provides a current threat reference; use versioned mappings alongside customer controls rather than promising complete coverage of a Top 10 list. Existing code already distinguishes mapped and effective coverage. [O1, C2]

Jurisdiction-specific requirements must be confirmed with the buyer's security, privacy, and legal owners during scoping. The attachment references EU obligations, but neither customer jurisdiction nor AI use-case classification is established here. No legal compliance conclusion is assumed.

10. Pilot scorecard and measurement rules

North-star outcome: Number of customer AI applications with current, reviewer-accepted security evidence and verified treatment of all material in-scope gaps. A documented, unexpired customer risk acceptance may count as treatment; it is reported separately from remediation. Count applications only within the declared supported boundary.

First-quarter focus: Convert one qualified demo prospect into a paid pilot that proves the evidence/remediation workflow. Avoid using discovered-asset volume, policy count, or dashboard engagement as substitutes for this outcome.

Measure	Definition and proposed threshold
Discovery coverage	Discovered supported in-scope resources / independently enumerated supported in-scope resources. Target >=95%; list excluded/unsupported resources separately.
Evidence freshness	Current time minus the latest valid source observation time supporting the assessment, within the control's freshness window. Daily-scan target: <=24 hours. Measure collection-to-assessment lag separately; retain stale/unavailable scopes in reporting.
Reviewed alert precision	Confirmed supported violations / reviewed actionable alerts. Target >=90%, with review count, severity mix, and uncertainty shown.
Scenario sensitivity	Detected agreed violations / violations in a held-out scenario set. Target >=90% overall; all critical deny/authorization scenarios must pass before enforcement. This is not field-wide attack recall.
Evidence-preparation effort	Active person-hours to assemble the agreed security pack, measured before/after on comparable scope. Target >=50% reduction by month 6 across two reviews; also report rework.
Verified remediation	Accepted fixes whose relevant controls pass on fresh evidence / accepted fixes due for verification. Never include policy disablement, suppression, or ticket closure alone.
Time to value	Access-ready date to a usable customer baseline. Target <=7 business days. Measure procurement/access waiting time separately.
Repeatability and cost	Installation <=5 engineering days; routine support <=4 hours/customer/week after onboarding; track managed-service and support costs against contracted revenue.

For the initial control pack, select **5-8** from this shortlist only when evidence supports them: accountable owner and registration; approved environment/provider/region; agent or service identity configuration; excessive tool permissions; exposed sensitive data connections; expected logging/control configuration; unapproved agent/tool/model versions; and expired exceptions. An attested sensitivity label or approved purpose remains distinguishable from discovered fact. Detection of actual data leakage needs separate runtime/content evidence.

For control qualification, target at least 30 independently labelled cases per released control, including at least 10 positive and 10 benign cases plus missing/stale/error cases. Keep qualification cases separate from held-out evaluation. Review all early live alerts; target 50 or more reviewed alerts across the pack for initial evaluation. These floors are insufficient on their own for production release: each control must meet its actual statistical and review gates. Small samples must be disclosed. Size the required corpus in phase 1 and release fewer controls if independent qualification capacity is constrained. Do not relax existing release-governance statistical gates merely to meet these planning floors. [C2, C9]

Six-week pilot rhythm: Week 1 confirms scope, access, and baseline; weeks 2-3 reconcile discovery and validate controls; weeks 4-5 triage and verify fixes; week 6 delivers evidence, value review, and a commercial decision. Customer access delays pause the operational pilot clock and remain visible in the mutual action plan.

11. Three-year strategy: expand the security boundary deliberately

The one-year plan is Year 1 of this strategy. The second and third years add narrower, separately qualified capabilities. They do not assume automatic hiring, bank-wide adoption, or universal prevention.

Period	Strategic focus	Core at 2 people	Additional scope at 3-4 people
Year 1 / months 1-12	Trusted posture, evidence, verified remediation	One provider and one workflow; first paid production customer	Repeat deployment and one bounded expansion experiment
Year 2 H1 / months 13-18	Runtime evidence and release assurance	One telemetry source; attributable incident reconstruction	Same core with stronger automation and review integration
Year 2 H2 / months 19-24	Renew and qualify the next control surface	Harden observation; renew customers; no new enforcement service	One gateway/tool-boundary enforcement pilot, only after its separate gate
Year 3 H1 / months 25-30	Broaden evidence and continuous reassessment	One additional metadata feed if paid demand exists	Cross-system evidence and one partner scanner integration
Year 3 H2 / months 31-36	Prove continuous assurance and delivery economics	Repeatable specialist product with retained customers	Harden an accepted enforcement integration or qualify one funded private deployment; choose one

The commercial expansion sequence is **additional applications/business units -> supported evidence sources -> a separately priced control capability**. Reuse current customer relationships before entering a new vertical or building a different deployment architecture. Year 2 can test an adjacent regulated segment if the same control pack works without a product fork.

Longer-term position: A customer-owned map of AI systems, principals, dependencies, policy decisions, and evidence, connected to the tools that can act. AI Grid should answer: What changed? Which approved boundary does that affect? Who is accountable? What evidence supports the next decision?

Architecture direction: Keep collection/evidence, policy evaluation, and enforcement adapters separable. Metadata arrives from provider APIs or approved telemetry sources; customer context enriches the records; versioned checks create explainable outcomes; ticketing/GRC receives evidence; an optional gateway/tool adapter enforces only its explicitly supported decisions. Reuse the current application rather than undertaking a microservices rewrite for appearance.

Do not make the AI Grid control plane a universal inline dependency. Later enforcement integrations need a tested local policy/cache and an explicit failure model. High-impact actions require a suitable authorization boundary and customer approval; low-risk observational workloads can continue while flagging telemetry loss, as agreed.

12. Year 2 H1: make supported agent activity attributable

Months 13-18 | October 2027-March 2028 | Outcome: One customer can reconstruct a meaningful AI action from trustworthy evidence. **Dependency:** Year 1 retention, two customers requesting substantially the same capability, and source access. **Accountable:** engineering lead; customer platform/IAM owner supplies instrumentation.

Y2-01. Qualify one authoritative telemetry integration

Work: Instrument one customer-selected gateway, agent framework, or tool boundary. Record agent, initiating principal, tool, policy/version, approval reference, action outcome, timestamp, and trace relationship where available. Minimize sensitive payloads at source.

DoD: The producer has tenant-bound registration, principal/source binding, independent certification against customer-labelled decision records, and passing revocation/expiry tests before its evidence can be classified authoritative. Uncertified evidence cannot satisfy authority-dependent controls. A 14-day window includes >=100 real executions and >=50 consequential events; >=95% of those events have usable approval, policy, and outcome evidence; >=90% of executions correlate to an agent; >=80% of version-applicable executions correlate to a version over a minimum sample of 50. Missing evidence remains unknown. Demonstrate privacy-canary rejection, deduplication, late events, outage/replay, and visible data loss. Label insufficient-volume customers as not yet qualified; synthetic tests cannot stand in for a real observation window.

Important existing gate: Current Program 2 logic requires at least two provider-connector sources marked as required for the gate, and every required provider connector must pass; telemetry adapters do not substitute. The one-source pilot above is a proposed separately reviewed adapter qualification, not a claim that Program 2 passes. Before shipping, either meet the original gate or implement an explicitly named, independently approved narrow product gate while leaving original Program 2 status unmet. No silent threshold relaxation. [C2, C11]

Y2-02. Produce a usable incident reconstruction

Work: Link runtime activity to the existing asset, ownership, policy, and finding records. Integrate one customer SIEM export route or reuse its existing telemetry destination. Represent absent or conflicting evidence explicitly.

DoD: A customer analyst can reconstruct three sanctioned scenarios end to end, identifying source, actor, relevant boundary, observed outcome, and missing links. Alert delivery meets a proposed p95 five-minute lag for the supported feed, with measured drop/late-event rates. Repeat/replay does not create duplicate cases. At least one incident exercise is completed without engineer-written database queries.

Y2-03. Bind security evidence to an application release

Work: Reuse agent-version manifests and component allowlists. Export security check results and reviewer decisions against a precise release/configuration version. At two-person capacity, deliver the export first; add a blocking CI/release integration only on the four-person track with separate paid demand and available capacity.

DoD: Both tracks produce version-bound evidence for two applications and flag every agreed unapproved-component or revoked-approval test. For the optional blocking integration, an unapproved component or revoked approval blocks the agreed release check in all negative tests; an approved release passes. Material change invalidates or reopens the relevant evidence. Emergency exception has named approval, expiry, and audit history. Demonstrate on two applications. An AI Grid release check does not replace the bank's model validation or change authorization.

13. Year 2 H2: introduce bounded control only when ready

Months 19-24 | April-September 2028 | Outcome: Renewal and reliable runtime observation; a four-person team may pilot one action-control integration. **Dependency:** Y2-01/Y2-02, funded demand, and an enforcement point the customer actually controls. **Accountable:** engineering lead for qualification; founder for commercial/support gates; customer IAM/platform owner for access and enforcement prerequisites; customer security reviewer for acceptance.

Y2-04. Integrate policy at one tool or gateway boundary

Capacity: Four-person track; defer with two people unless separately staffed. **Work:** Support a short explicit rule set: approved principal/agent/tool, allowed action/resource, approved destination, and approval required for a selected consequential action. Reuse the customer's IAM and policy engine where possible.

DoD: Every allowed/denied test action has attributable identity, policy version, reason, and audit reference. Wrong audience, expired/revoked identity, missing authority, and direct-path bypass attempts fail in the supported boundary. The customer demonstrates that the protected tool cannot be reached through an ungoverned route within the contracted scope. Material-action approvals bind approver, action, resource, expiry, and one-time use. The first pilot protects a reversible, noncritical action; payments or irreversible core-banking actions are excluded.

Use MCP security guidance where applicable: validate token audience, avoid token passthrough, minimize scopes, and test confused-deputy paths. Pin the protocol version and qualify supported transports; metadata observation alone cannot establish these protections. [M1]

Y2-05. Prove enforcement does not create an uncontrolled outage

Capacity: Follows Y2-04. **Work:** Run shadow decisions first; then a bounded canary with explicit timeout, fail-open/fail-closed behavior, circuit breaker, policy cache, and rollback. Keep data inspection as a separate specialist integration if required.

DoD: At least 30 days of shadow operation and 1,000 labelled action decisions across live and sanctioned test traffic, reported separately. All agreed critical authorization tests pass; benign false-block rate is <=0.5% with counts/uncertainty reported. Proposed added p95 policy latency is <=100 ms excluding human approval and model inference. Revocation, stale policy, gateway outage, replay, and rollback drills pass; disablement/rollback completes within five minutes. Customer signs the enforcement boundary and canary decision. No prevention claim extends to bypassed or unsupported traffic.

Y2-06. Earn renewal and prove support economics

Work: Convert accepted runtime value into a paid expansion; review core customers for renewal. At two-person capacity, sell dependable observation/evidence rather than an unsupported inline service.

DoD: At least two independent paying production customers use the repeatable core; the first contract reaching renewal is renewed or expanded. At least one customer pays for the added runtime capability before it receives an open-ended support commitment. After onboarding, support remains <=4 engineering hours/customer/week. Proposed contribution margin is >=60% after hosting, tooling, and directly attributable support, excluding R&D and sales; price or scope changes address a miss.

Year 2 exit: Runtime observation is qualified in one boundary. Enforcement is claimed only if Y2-04/Y2-05 pass; otherwise it remains a pilot or is deferred.

14. Year 3: continuous assurance across selected systems

Months 25-36 | October 2028-September 2029 | Outcome: A retained customer can see how material changes affect approved AI security boundaries across a small, explicit integration set. **Dependency:** Year 2 renewal, stable quality, and affordable support. **Accountable:** engineering lead for technical qualification; founder for capacity, contracts, and support; customer platform/IAM owner for integration/deployment prerequisites; customer security reviewer for acceptance.

Y3-01. Add one complementary evidence source | Months 25-28

Work: Choose a second cloud/AI platform **or** an existing SSE/CASB/proxy/identity feed for unregistered AI usage. Avoid building a browser extension or endpoint fleet. Link observed usage to declared inventory with confidence and source provenance.

DoD: Two customers request the same source; at least one funds it. Supported-scope reconciliation reaches >=95% against the agreed independent baseline. Duplicate/conflicting identities are surfaced, not silently merged. A seeded unregistered service is flagged and a declared service is correctly matched. Unknown browser/SaaS/embedded AI remains a stated blind spot. Two-person teams stop at this extension plus core hardening.

Y3-02. Reassess cross-system changes | Months 27-30

Work: Link approved applications to supported agents, tools, models, data-context references, and policies across the qualified sources. Begin with read-only evidence correlation. **Capacity:** Four-person track after Y3-01.

DoD: Five customer-agreed change scenarios produce the correct impacted applications, control gaps, and reviewer tasks. A reviewer can reconstruct each cross-system path with source timestamps and confidence, including gaps. Ten sampled approved applications have a complete evidence chain for the contracted controls, or all applications if the estate is smaller. Customer evidence is exportable in a documented format without proprietary UI dependence.

Y3-03. Connect component provenance and specialist evaluations | Months 29-32

Work: Integrate one paid-demand model/component scanner or evaluation system. Attach supplier/version, digest where available, evaluation result, approval, and expiry to the relevant application release. **Capacity:** Four-person option; choose this before private deployment, not simultaneously.

DoD: A changed or disallowed component invalidates the matching approval in all agreed tests. Scanner findings map to a precise component/version and retain source and scope. An approved benign release is not blocked by unrelated results. Two application releases use the integration. Do not claim model fairness, accuracy, malicious-weight detection, or training-data safety beyond what the integrated assessment actually measures.

Year 3 continued: operational proof

Y3-04. Select one funded enterprise expansion | Months 31-35

Work: Choose either hardening the accepted action-control integration **or** qualifying one customer-controlled deployment/collection pattern. A private deployment requires a funded support owner/partner and repeat demand; the roadmap does not assume air-gap support.

DoD: Control option passes independent bypass, failover, revocation, and rollback review at contracted load. Deployment option demonstrates no unapproved outbound traffic, installation/upgrade, backups/restore, evidence export, and agreed residency/retention in the customer environment. A second install uses the same documented package. Customer funds the required operational coverage; a 2-4-person team does not silently inherit 24/7 global operations.

Y3-05. Prove continuous assurance and sustainable growth | Months 34-36

Work: Automate evidence refresh for supported changes and publish customer-specific coverage, health, and decision histories. Review renewal, expansion, support burden, and whether a second vertical can use the same product.

DoD: A 90-day customer evaluation shows >=95% fresh evidence for applicable contracted controls. Stale or unavailable evidence remains in that denominator as a miss; explicitly nonapplicable controls and approved exceptions are disclosed separately. Reviewers accept two successive periodic evidence packs and a cross-system incident/change exercise. At least two renewal/expansion decisions across the installed base succeed. Target three retained paid production customers at two-person capacity or five at four-person capacity, only while the same quality and contribution-margin gates hold. These are capacity-based targets, not market forecasts.

Year 3 boundary: General autonomous remediation, universal multi-cloud blocking, full model-risk governance, and air-gapped operation remain separate investment decisions. Any later automated remediation starts with approved, reversible actions and explicit recovery tests.

15. Capacity, dependencies, and stop rules

The roadmap uses work already present in the codebase. The committed first-year work is productization, validation, and narrowly targeted gaps. A reliable new control surface costs more than another screen or policy mapping.

Team	Practical allocation	Scope consequence
2 people	Technical founder splits buyer discovery/product/integration; one engineer owns delivery. Obtain fixed-scope external security review. Keep one engineering workstream active.	Commit to one provider, one workflow, 5-8 controls, and core evidence/operations. Defer inline enforcement and simultaneous new deployments.
3 people	Founder leads commercial/product; two engineers split core workflow and integration/quality, still working toward one milestone.	Accelerate reliability and repeat onboarding; select one expansion only after support is stable.
4 people	Founder/product; backend/integration engineer; product/full-stack engineer; platform/security engineer, with independent external review.	Core plus one bounded runtime/enforcement or integration track. Two substantial new surfaces still exceed safe capacity.

Reserve approximately 35-40% of engineering capacity for testing, security fixes, operations, customer integration problems, and support. Founder sales/procurement time is additional. Initial planning allowance for first-year incremental delivery is roughly 10-12 engineer-months at two people and 20-24 at four, after those constraints; validate with backlog sizing in week 2. These are planning estimates, not a costed delivery promise.

Dependency chain: buyer/access -> secure environment -> reconciled discovery -> validated controls -> remediation/evidence acceptance -> production conversion -> repeat onboarding -> runtime evidence -> separately qualified enforcement -> selective federation. Failure at an earlier gate keeps dependent capability in pilot or deferred status.

Trigger	Management response
No paid pilot after 6-8 relevant buyer conversations or by month 3	Reassess urgency, buyer, procurement route, and offer. Continue necessary trust fixes; stop adjacent product expansion.
Customer evidence cannot support a promised control	Remove or relabel the claim; expose the evidence gap; choose another control or source with the buyer.
First pilot needs multiple bespoke systems or a new hosting model	Reduce scope, price a separate discovery engagement, or disqualify it as the first repeatable customer.
Precision, isolation, restore, or data-handling gate fails	Hold release; remediate and retest. Commercial pressure does not make the gate pass.
Support exceeds its budget for two consecutive months	Pause new integrations; fix the dominant issue, adjust scope/pricing, or fund delivery capacity.
A buyer requires certification or 24/7 operations before purchase	Establish exact requirement and funded partner/auditor path before committing. Choose a more suitable initial buyer if economics do not work.

Additional hires become justified when signed revenue or funding covers a sustained new support obligation. A broader multi-cloud or private-deployment program needs named engineering/security/operations capacity, not assumed future headcount. Keep opportunity cost visible: every new integration delays trust, conversion, or renewal work.

16. The next 30 days

Window	Action	Concrete output / owner
Days 1-5	Review current demo pipeline and choose the strongest buyer/problem hypothesis. Inventory claims against current code.	Ranked prospects and capability matrix; founder + engineering lead.
Days 6-10	Conduct 6-8 interviews; select provider, use case, budget owner, risk reviewer, and access owner.	Draft fixed-scope pilot charter with success and purchase decision; founder.
Days 11-15	Rehearse the existing end-to-end flow with sanitized data. Scope auth, privacy, deployment, and recovery gaps.	Customer-reviewable architecture/data-flow pack and sized critical backlog; engineering lead.
Days 16-20	Qualify candidate controls and prepare source-of-truth inventory reconciliation.	Versioned positive/negative/unknown cases, coverage matrix, and evidence-pack sample; engineering lead + customer reviewer.
Days 21-30	Close the paid pilot terms, complete access prerequisites, and establish baseline measurements.	Signed charter/PO, readiness report, first assessment date, and scheduled commercial readout; founder.

The month-1 operating review should answer four questions with evidence: Is there a buyer? Can that buyer supply the required evidence? Can the existing product produce a trusted decision? Will the result justify continued payment?

Product principle: Enterprise grade means dependable within an explicit supported boundary. Expand that boundary only after its evidence, controls, recovery, and economics have been demonstrated.

17. Sources and traceability

B - Bank strategy. User-provided *AI in Bank.pdf*, 49 pages. Full text reviewed; image-heavy architecture, maturity, roadmap, and blocker pages also visually inspected. Primary references: pp. 7-9 institutional ownership; pp. 11-17 inventory and policy; pp. 18-21 architecture/maturity; pp. 29-36 identity/telemetry; pp. 39-40 sovereignty; pp. 46-48 planned roadmap; p. 49 adoption blockers. The source includes planning statements, not independently verified delivery. Local source: /Users/gowrikarthik.gadela/Downloads/AI in Bank.pdf.

The following links identify the local implementation evidence reviewed. They describe the working tree at review time; no application or deployment changes were made for this strategy.

- **C1 - Inventory UI:** AiInventoryPage.tsx, line 112.
- **C2 - Pipeline, governance, coverage, and runtime status:** Business logic guide, line 330; runtime gate at line 425 and preview/validation caveats around line 478.
- **C3 - Collection privacy boundary:** AiSecurityMetadataSanitizer.java, line 14.
- **C4 - Evidence and uncertainty:** AiGridSnapshotService.java, line 68; AiGridAssessmentService.java, line 145.
- **C5 - Findings and reassessment:** AiGridFindingService.java, line 54.
- **C6 - ServiceNow path:** AiGridFindingIncidentController.java, line 31.
- **C7 - Existing JWT support:** JwtDecoderConfig.java, line 20.
- **C8 - Isolation/production configuration:** TenantAwareDataSource.java, line 87; application-prod.yml, line 32.
- **C9 - Policy release and demo-only behavior:** AI Grid release runbook; AiGridDemoPolicyAutoPublishService.java, line 19. The runbook's runtime gate summary is less complete than the current service/business-logic guide; reconcile documentation before release.
- **C10 - Runtime API limitations:** AzureFoundryRuntimeCollectionService.java, line 51; CopilotStudioRuntimeCollectionService.java, line 44.
- **C11 - Runtime readiness implementation:** AiGridRuntimeTelemetryReadinessService.java, line 19.
- **C12 - Existing CI:** quality.yml, line 11; performance-governance.yml, line 44.
- **C13 - Local GTM context:** SCOUTGRID_GTM_30_60_90.md.

Public references were checked on 27 September 2026; no confidential source content was submitted in web searches.

- **N1:** NIST AI Risk Management Framework. Voluntary framework and revision context.
- **N2:** NIST AI 600-1: Generative AI Profile. Companion risk-management reference.
- **O1:** OWASP GenAI LLM Top 10 2026. Versioned threat reference, not a certification.
- **M1:** MCP Security Best Practices, 2025-11-25 documentation. Token audience, passthrough, consent, and scope-related security guidance.

The phase sequencing, feature choices, commercial targets, staffing assumptions, and quantitative DoDs are recommendations derived from the supplied context. They are not requirements issued by the bank, verified market benchmarks, or claims that AI Grid has already achieved them.